

PsyClick: Clinical Decision Support System for Detecting Single-Session Psychomotor Disturbances via EWMA-Based Multivariate Analysis of Keystroke and Cursor Dynamics

by

Ayaay, Martonie Loreign L.
Ballano, Denise Nicole M.
Huertas, Lana Denise R.
Tablate, Judea Ann C.

Security Documentation

FEU Institute of Technology
July 2026

©2026 Ayaay, Martonie Loreign L., Ballano, Denise Nicole M.,
Huertas, Lana Denise R., Tablate, Judea Ann C.
All Rights Reserved

1. Purpose and Scope

This document is the consolidated Security Documentation for PsyClick Secure, required under the CS0029 Final Project Specification (Section IV.B, item 2). It brings together, in a single deliverable, the Threat Model, Risk Assessment Matrix, Security Policy, Incident Response Plan, and Backup and Recovery Plan for the psyclick-secure application.

The content is consistent with the security analysis in Chapter 5 of the PsyClick thesis and the companion Risk Assessment Report and Security Testing Report. Scope is limited to the psyclick-secure application — a separate, hardened build of the PsyClick clinical decision-support prototype — running

as an Electron/React frontend against a local Flask API bound to 127.0.0.1:5101, backed by a local SQLite database.

2. Threat Model

2.1 Assets, Actors, and Trust Boundaries

Assets: patient/client identifiers, consent, screening scores, telemetry, derived features, T²/PSI/PAI results, reports, accounts, session tokens, keys, audit logs, backups, and clinical trust. Actors: unauthorized local users, compromised accounts, malware, accidental users, supply-chain attackers, and participants attempting administrative access. Trust boundaries: patient interaction, Electron renderer, loopback API, protected SQLite data, backup target, and administrator functions.

2.2 STRIDE Threat Analysis

STRIDE Category	Affected Component	Representative Threat	Existing / Recommended Control
Spoofing	Login / session bootstrap	Credential guessing; replayed session token	scrypt-hashed credentials, lockout policy, server-side bearer sessions; MFA recommended
Tampering	SQLite data store, audit log	Direct file edit, log entry alteration	Parameterized SQL, hash-chained audit log with verification endpoint
Repudiation	Clinician actions, exports	Denial of having performed an export or access	Per-action audit events (login, denial, consent, access, export, backup)
Information Disclosure	Reports, backups, temp files	Plaintext export, unencrypted backup copy	DPAPI-protected exports/backups, SHA-256 verification digest
Denial of Service	Loopback API	Repeated requests, disk/resource exhaustion	Loopback binding to 127.0.0.1, bounded inputs, transaction handling
Elevation of Privilege	Role middleware	Clinician acting with administrator scope	Role-based middleware, ownership-scoped queries, deny-by-default routing

2.3 Threat Identification

Threat Identification	PsyClick Exposure	Current Control / Required Follow-up
Unauthorized access	Compromised or shared clinician account; direct local API attempt	Hashed credentials, lockout, server sessions, RBAC, ownership scope; MFA remains recommended
Data leakage	Database, report, backup, temporary file, or external transfer	DPAPI exports/backups, local-first design; institutional encryption/key policy required
Malware infection	Compromised workstation or ransomware	Least privilege, endpoint controls, encrypted backups; operational endpoint policy required
Insider threat	Excessive access, export, or record browsing	RBAC, ownership scope, hash-chained audit review
Denial of Service	Repeated requests, disk exhaustion, corrupt state	Loopback binding, input limits, transactions, monitoring and

		operational recovery
SQL injection	Malicious text/identifier input	Parameterized queries and validation; dynamic test evidence still required
Cross-Site Scripting	Untrusted content rendered in report/UI	React escaping and fixed templates; dynamic XSS test still required

3. Risk Assessment Matrix

Each risk is scored by likelihood and impact on the confidentiality, integrity, and availability of clinical data, with the mitigation currently implemented in the psyclick-secure build. A full risk register with inherent-versus-residual scoring is provided in the companion Risk Assessment Report.

Risk	Likelihood	Impact	Mitigation
SQL injection / malicious input	Medium	High	Parameterized queries, input validation, negative tests
Data breach / plaintext export	Medium	High	DPAPI-protected exports, encrypted database/backup policy, restricted paths
Account hijacking	Medium	High	script, lockout, session expiry/revocation, MFA recommended before institutional use
Unauthorized access / IDOR	Medium	High	Bearer sessions, RBAC, ownership-scoped queries, deny-by-default middleware
Malware / ransomware	Medium	High	Endpoint protection, least privilege, encrypted verified backups
Insider misuse	Possible	High	Least privilege, audit chain, administrator review, separation of duties
Denial of Service	Unlikely	Moderate	Local binding, bounded inputs, resource monitoring, graceful failure
XSS / unsafe report content	Unlikely	High	React escaping, fixed report template, no untrusted HTML injection; dynamic scan pending
Brute-force / credential stuffing	Low (post-mitigation)	High	Per-account lockout (5 attempts/15 min) plus threshold-based intrusion monitor (8 failures/5 min) that throttles and logs a security audit alert
Vulnerable build-toolchain dependencies	Low	Moderate	npm audit reduced 16 to 8 advisories via non-breaking fixes; remaining

			advisories confined to devDependencies not shipped in the packaged app
--	--	--	--

4. Security Policy

The following policy applies to every clinician, administrator, and auditor who uses PsyClick Secure:

- Use unique accounts and apply least privilege.
- Require recorded consent before any telemetry capture.
- Collect only approved data and protect restricted files.
- Prohibit unencrypted email or file sharing of reports.
- Log all access and exports.
- Retain no semantic typed content unless separately approved.
- Patch and lock workstations.
- Verify encrypted backups.
- Report suspected loss, malware, unauthorized access, consent failure, corruption, or disclosure immediately.
- Never treat PsyClick output as a diagnosis.

5. Incident Response Plan

The incident-response lifecycle follows six phases: preparation → identification → containment → eradication → recovery → post-incident review.

The Incident Coordinator, System Administrator, Data Protection Officer / Privacy Lead, Clinical Lead, and management / communications roles are defined in this document and applied consistently across the project.

Critical incidents include restricted-data exfiltration, ransomware, key compromise, and widespread unauthorized access. These are escalated immediately and trigger containment and administrator notification.

6. Backup and Recovery Plan

The secure build creates an encrypted SQLite backup, records its SHA-256 digest and metadata, and validates the copy in an isolated temporary directory using SQLite integrity_check.

Operational deployment should use daily / after-session backups, weekly full backups, and encrypted / offline separation, with a proposed 24-hour Recovery Point Objective (RPO), a proposed 4-hour Recovery Time Objective (RTO), and quarterly restoration drills.

The executed regression test is synthetic and is not a substitute for an institutional restore drill.

6.1 System Redundancy

PsyClick Secure is a local-first, single-workstation deployment, so the application itself does not provide server-level clustering or automatic failover; a single workstation is therefore a single point of failure. Availability is instead protected through data redundancy and recoverability rather than hardware duplication:

- Encrypted backup copies are kept on separate, offline media (removable or institutional storage), so at least one copy is independent of the primary workstation.
- Every backup is integrity-verified with a SHA-256 digest, so a corrupt copy is detected before it is relied upon.

- The recommended schedule (daily / after-session and weekly full backups) maintains multiple recovery points and bounds data loss to the proposed 24-hour RPO.

For institutional deployment, stronger redundancy is recommended as a future enhancement and lies outside the local-first prototype boundary: a standby / failover workstation holding the packaged application, redundant backup storage (for example RAID or replicated network storage), and — if a central data store is later introduced — database replication with periodic failover testing.

7. Approval

Name	Signature
Ayaay, Martonie Loreign L.	
Ballano, Denise Nicole M.	
Huertas, Lana Denise R.	
Tablate, Judea Ann C.	